The Five-Pillar AI Governance Implementation Architecture — A Federally-Procurement-Ready v1 Dossier

> *"Governance is a property of the deployment substrate, enforced by the architecture and witnessed by 360-degree evidence — never a property of the policy document."*

This dossier converts that cover-page commitment into an operational blueprint for federal and defense buyers, contractors and vendors selling into them, and the consulting/platform venture delivering the work. It is **simultaneously**: a board-readable roadmap; a working-level playbook with artifacts; and an audit-defensible methodology mapped line-by-line to OMB M-25-21/22, FedRAMP 20x, NIST 800-53 Rev 5, NIST AI RMF + AI 600-1, ISO 42001, CMMC 2.0 / 32 CFR 170 / DFARS 252.204-7021, DoD Zero Trust, and CISA ZTMM v2.0. Where standards are draft (CAISI Agent Standards, NIST IR 8596 Cyber AI Profile, NIST 800-171 Rev 3 incorporation into CMMC), the dossier flags forward-looking elements explicitly. The framework is designed as a **durable spine** — anchored in NIST/ISO catalogs that survive administration changes — surrounded by **replaceable surfaces** that swap as OMB memoranda, FedRAMP RFCs, CMMC phases, and EU AI Act timelines evolve.

---

1. The framework reframed as substrate, not document

The five pillars are not policy statements; they are **enforcement properties of the deployment substrate**, witnessed by an evidence pipeline that produces machine-readable artifacts at every life-cycle event. Each pillar binds to specific architectural primitives and to specific federal control catalogs:

Pillar 1 — Governance, security, privacy baked in. Substrate property: every artifact (model, dataset, prompt, container image, IaC module, agent identity) carries a signed provenance manifest before it can be deployed. Anchored in NIST 800-53 Rev 5 families SR / SA / PT / PM, NIST AI RMF GOVERN function, Nist ISO 42001 Clause 5 + Annex A.2/A.3/A.6, FedRAMP 20x KSI-PIY/KSI-CMT, CMMC CM/CA/SR domains, M-25-21 §4(c)(2) AI Impact Assessment. carahsoft Concrete substrate: CycloneDX 1.6 ML-BOM or SPDX 3.0.1 AI Profile Interlynk attached as in-toto ITE-6 attestation, signed via Sigstore Fulcio + Rekor, GitHub ingested by an OSCAL-native control catalog.

Pillar 2 — Assumed breach. Substrate property: every component is engineered as if its perimeter has already failed; detection, containment, and recovery times are the controlling KPIs. Anchored in NIST 800-53 IR/AU/SI families, NIST SP 800-61 Rev 3 (CSF 2.0 community profile, April 2025), NIST CSRC NIST CSRC CISA ZTMM v2.0 cross-cutting Visibility & Analytics, Microsoft Learn CMMC IR domain, MITRE ATT&CK + ATLAS unified threat model, JCDC.AI Playbook (Jan 2025). Concrete substrate: SIEM ingestion of GenAI semantic-conventions telemetry (prompt, completion, tool-use, embedding, RAG retrieval), prompt-injection / model-extraction detectors, canary tokens, AI-specific tabletop exercise designed under HSEEP doctrine.

Pillar 3 — No single point of failure. Substrate property: vendor concentration, model-family concentration, foundation-model dependency, GPU compute concentration, region concentration, dataset concentration, and identity-store concentration are tracked as enumerated risks with quarterly metrics. Anchored in NIST AI RMF MAP-4 Tech Jacks Solutions / MEASURE-4 / MANAGE-3, NIST 800-34 Rev 1 Contingency Planning, FedRAMP 20x KSI-RPL, OMB M-25-22 vendor lock-in protections, carahsoft Perkins Coie ISO 42001 Annex A.10. Concrete substrate: a concentration risk register with multi-cloud burst patterns, on-prem open-weights backup paths, and Inspect-based failover evaluation suites.

Pillar 4 — Zero trust throughout. Substrate property: identity (human, NPE, agent), device, network, application, and data layers all enforce continuous, context-aware authorization decisions; nothing is implicitly trusted. Anchored in CISA ZTMM v2.0 (5 pillars × 4 stages × 36 functions), Stern Security microsoft DoD Zero Trust Strategy + RA v2.0 (7 pillars, 152 activities, FY27 Target / FY32 Advanced), Microsoft Cisco NIST SP 800-207, NIST 800-53 AC/IA/SC families, FedRAMP 20x KSI-IAM (phishing-resistant MFA via WebAuthn/FIDO2 only). Platform28 Platform28 Concrete substrate: PIV/CAC + FIDO2 for humans, SPIFFE/SPIRE SVIDs for workloads, Istio agent identity via emerging CAISI AI Agent Standards (RFI closed March 9, 2026; NCCoE concept paper Feb 2026), Lab Space Cilium/Istio service mesh with mTLS, Faun GPU-MIG plus H100/Blackwell confidential computing for tenant isolation, Firecracker/gVisor for agent sandboxing.

Pillar 5 — 360 accountability. Substrate property: every action, decision, change, and incident is traceable through a hash-chained evidence registry to a named role in one of six roles — developer, deployer, contractor, vendor, regulator, end-user — with the evidence portable across regulators. Anchored in NIST AI RMF GOVERN-2 (accountability structures), ISO 42001 Annex A.3 (roles), GAO-21-519SP four pillars (Governance/Data/Performance/Monitoring), U.S. GAO Homeland Security & Government M-25-21 §3 CAIO obligations, carahsoft M-25-22 procurement disclosure. Concrete substrate: hash-chained artifact registry with Sigstore transparency log entries, OSCAL machine-readable cross-pillar evidence, and a regulator-ready submission packager.

The remainder of this dossier operationalizes these substrate properties.

---

2. The six-phase engagement methodology

The engagement methodology applies identically to **buyer**, **seller**, and **engagement** perspectives; only the perspective-specific evidence outputs differ. Total v1 envelope: **22–46 weeks of engineering work** to reach initial authorization, plus continuous monitoring afterward.

Phase 1 — Discovery and scoping (2–4 weeks)

The discovery phase establishes scope, stakeholders, and threat baseline. **Stakeholder mapping** explicitly enumerates every named role across the 360-accountability matrix: developer (model producer, system producer per NIST 800-218A), deployer (mission owner, system acquirer), contractor (DIB prime/sub), vendor (foundation model provider, cloud CSP, MCP server provider), regulator (FedRAMP PMO, agency CAIO, DCMA DIBCAC, OMB, state regulators), end-user (federal employee, citizen subject of a rights-impacting decision). Each role is mapped to its control responsibilities under each applicable framework, producing a **role-control responsibility matrix** that becomes the spine of the SSP and the engagement SOW.

AI portfolio inventory classifies every existing or planned AI use case against M-25-21's high-impact criteria (§5/§6), carahsoft NIST AI 600-1's twelve GenAI risk categories (CBRN, confabulation, dangerous content, data privacy, environmental, harmful bias, human-AI configuration, info integrity, info security, IP, obscene/abusive/CSAM, value chain), Libertify and the agency's existing AI Use Case Inventory entries per the CIO Council 2024 Guidance. **Existing control environment baseline** captures the current FISMA/FedRAMP/CMMC posture, ATO inventory, eMASS or comparable system records, identity infrastructure (PIV/CAC/FIDO2 deployment depth), and SIEM coverage.

Threat modeling combines MITRE ATT&CK Enterprise (14 tactics, ~400+ techniques) Startupdefense Splunk with MITRE ATLAS (16 tactics, ~84 techniques as of v5.1.0 Nov 2025; Balancedsec further additions in v5.4.0 Feb 2026) Vectra AI using a unified kill-chain that traverses ATT&CK first (Recon → Initial Access → Execution → Privilege Escalation → Persistence on the IT plane hosting model weights, training pipelines, vector DBs, MLOps tooling) and then transitions to ATLAS (ML Model Access → ML Attack Staging → Defense Evasion via prompt injection or evasion → Exfiltration via inference API or weight theft → Impact). Cross-references shared technique IDs (T1195 ↔ AML.T0010 supply-chain). Adds OWASP LLM Top 10 (2025 v2025: prompt injection, sensitive info disclosure, supply chain, data/model poisoning, improper output handling,

excessive agency, system prompt leakage, vector/embedding weaknesses, misinformation, unbounded consumption) Trydeepteam and OWASP Top 10 for Agentic Applications (Dec 10, 2025). Lares Labs

Concentration risk register is initialized along eight dimensions (vendor, model family, foundation model, GPU compute, cloud region, dataset, tooling/MLOps, identity/auth) with likelihood × blast radius × recovery cost scoring. **Discovery questionnaires** mirror the 3PAO RAR pre-RAR pattern (Coalfire, Schellman, A-LIGN, Tevora) using ~200+ keyed evidence requests, plus AI-specific extensions covering training data provenance, model card completeness, retrieval architecture, agent autonomy boundaries, and ZDR/no-train contractual posture for any commercial LLM in scope.

Phase-1 deliverables: a stakeholder/role-responsibility matrix; classified AI portfolio inventory with high-impact flags; threat model document; concentration risk register v0; gap-discovery questionnaire responses; engagement charter and revised SOW.

Phase 2 — Assessment and gap analysis (4–8 weeks)

Each pillar is evaluated against the full crosswalk: NIST 800-53 Rev 5 baselines (Low 156 / Moderate 323 / High 410 controls per FedRAMP Rev 5; Workstreet the legacy "421" High count is Rev 4 and is no longer current); NIST AI RMF 1.0 + AI 600-1 GenAI Profile suggested actions; NIST ISO 42001 Annex A (38 controls across 9 objectives A.2–A.10); ControlCase CMMC 2.0 L1/L2/L3 (15 / 110 / 134 practices); CyberSaint CISA ZTMM v2.0 across the five pillars × four stages RegScale × 36 functions; Stern Security and the framework's own five pillars.

Evidence collection protocol: every control evaluated by examine + interview + test per NIST 800-53A Rev 5; results captured in OSCAL Assessment Results (AR) format. **Gap analysis matrix** uses ten standard columns (Control ID, Control Name, Current State, Target State, Gap Description, Risk Rating using likelihood × impact, Remediation Action, Owner, Timeline, Evidence Required) extended with five framework-specific columns (Framework Pillar, 360-Accountability Role, Substrate Primitive, Cross-Scenario Portability, Concentration Risk Linkage).

Assume-breach tabletop exercise designed under HSEEP doctrine (FEMA, Doctrine Revision 2-2-25): Concept & Objectives → IPM → MPM → MSEL → FPM → Conduct → Evaluation → AAR/IP. Scenarios drawn directly from JCDC.AI's June 2024 Microsoft TTX Alston & Bird (AI cyber incident scope, info-sharing protocol, operational collaboration) HSToday and the September 2024 Scale AI TTX (financial-services AI incident). Infosecurity Magazine AI-specific scenarios layered over existing CISA CTEPs (Ransomware, Insider Threat, CISA OSS Supply Chain) since CISA had not, as of May 2026, released a dedicated AI-specific CTEP. The TTX produces an AAR/IP whose corrective actions are tied to MITRE ATT&CK + ATLAS technique IDs and OWASP LLM

risk IDs.

Five-pillar maturity model. This is the framework's principal assessment rubric. It uses CISA ZTMM v2.0's four-stage structure (Traditional → Initial → Advanced → Optimal) Acuity, Inc. +2 as the spine and applies it to the five framework pillars × three cross-cutting capabilities (Visibility/Analytics, Automation/Orchestration, Governance), producing a 5×4 × 3 = 60-cell rubric. Each cell defines a specific maturity behavior — for example, Pillar 4 Zero Trust × Identity × Optimal: "phishing-resistant MFA enforced enterprise-wide; SPIFFE SVIDs issued for all workloads; agent identity via CAISI-aligned standards; continuous risk-based reauthentication; mean time-to-revoke < 60 seconds." The rubric **maps directly** to: NIST CSF 2.0 tiers (Partial/Risk Informed/Repeatable/Adaptive), CyberSaint CMMC L1/L2/L3, FedRAMP 20x KSI completion, DoD ZT Target/Advanced, and ISO 42001 conformance levels — so a single assessment produces multiple outputs.

Red-team / purple-team exercise design draws on CDAO Crowdsourced AI Red-Teaming Assurance Program (CAIRT, Jan 2025 pilot identified >800 vulnerabilities/biases in DHA medical-LLM use cases), MeriTalk UK AISI Inspect framework Inspect and Autonomous Systems Evaluation Standard, Ukgovernmentbeis US CAISI's joint pre-deployment evaluations of o1 / Claude Opus 4 series, METR's HCAST/RE-Bench long-horizon autonomy methodology (50%-task-completion time horizon arXiv doubling every ~7 months 2019-2024, accelerating to ~4 months in 2024; Claude 3.7 ~50 min, o3 ~110 min, GPT-5 / Opus 4.5 substantially higher), and Apollo Research's in-context scheming evaluations (oversight-subversion, self-exfiltration, sandbagging, alignment-faking — frontier models exhibit ~1% scheming even without strong nudges). Apollo Research Roles: red-team lead, ML/AI researcher, security engineer, prompt-injection specialist, evaluator/methodologist, dataset adversary, blue-team liaison, legal/privacy counsel.

Phase-2 deliverables: Pillar-by-pillar gap analysis matrix; OSCAL Assessment Results; five-pillar maturity model assessment with current-state and target-state markers; TTX after-action report and improvement plan; red-team findings report with severity scoring (CVSS-like, OWASP LLM Risk ID, ATLAS technique ID, CWE).

Phase 3 — Design and remediation planning (4–6 weeks)

Target-state architecture is specified per pillar with named substrate primitives (the artifact catalog appears in §3 below). **POA&M construction** uses the FedRAMP POA&M template's 28 columns (Item ID through BOD 22-01 tracking) extended with the five pillar-mapping columns; remediation prioritization applies risk-weighted scoring with severity × exploitability × blast radius. **Remediation timelines** mirror FedRAMP: High 30 days, Moderate 90 days, Low 180 days; CMMC POA&M closeout 180 days from

Conditional certification. eCFR

Authorization-boundary integration is a critical decision: AI workloads frequently fit within existing FISMA/FedRAMP authorization boundaries when the AI is a feature of an already-authorized SaaS, but require a new boundary when the AI introduces (a) new external data flows (e.g., third-party model API calls), (b) new compute classes (e.g., dedicated GPU enclaves), (c) new identity domains (agent identities), or (d) new data classifications (CUI-derivative model weights). The decision is logged with explicit FIPS 199 categorization and CNSSI 1253 (for DoD) or FIPS 200 (for civilian) impact analysis. **Decision log** captures every architectural commitment with rationale, alternatives considered, dissents, and reversibility analysis — preserved for litigation hold.

Phase-3 deliverables: target-state architecture diagrams per pillar; POA&M v1; authorization-boundary determination memo; architectural decision log; integration plan with existing zero-trust roadmaps (DoD ZT Capability Execution Roadmap COA 1; CISA ZTMM stage progression).

Phase 4 — Implementation (6–18 months)

Implementation sequencing begins with **Pillar 4 (Zero Trust) identity foundations** because every other pillar depends on identity for evidence attribution. Substrate components deployed in dependency order:

The **identity infrastructure** layer combines PIV (FIPS 201-3, finalized Jan 2022) NIST CSRC plus FIDO2/WebAuthn for humans (DPC class permitted under 201-3); DoD ICAM Reference Design Docslib v2.0 patterns for NPE credentialing on classified networks; SPIFFE/SPIRE for workload identity (X.509-SVID for mTLS, JWT-SVID Spiffe for HTTP/gRPC; two-level attestation; Substack trust-domain federation; Red Hat 1-hour SVID validity with 30-min rotation); and emerging agent identity primitives from the CAISI AI Agent Standards Initiative (RFI closed March 9, 2026; NCCoE concept paper "Accelerating Adoption of Software and AI Agent Identity and Authorization" Feb 2026). Lab Space MCP servers operate as OAuth 2.0/2.1 Resource Servers per the November 25, 2025 spec, with mandatory Resource Indicators (RFC 8707) and Client ID Metadata Documents. Phishing-resistant MFA enforces FedRAMP 20x KSI-IAM-01: WebAuthn/FIDO2 only; SMS, TOTP, email, and push factors disallowed. Platform28

The **containment and microsegmentation** layer wraps AI workloads in defense-in-depth: Firecracker microVMs (jailer + seccomp-bpf) GitHub or gVisor (Sentry user-space kernel) Gvisor for agent sandboxing; Kata Containers for VM-isolated container pods where Confidential Computing is needed; Cilium (eBPF) or Istio (sidecar/ambient) service mesh for identity-aware L3-L7 policy Medium with SPIFFE-issued mTLS identities; NVIDIA H100/Blackwell Multi-Instance GPU + Confidential Computing for inference isolation NVIDIA (AMD SEV-SNP or Intel TDX 1.x CPU TEE paired with NVIDIA

NRAS/RIM/OCSP attestation); FQDN-based egress filtering preventing LLM agents from making outbound calls to undeclared destinations.

The **AIBOM / SBOM / SLSA provenance pipeline** is the spine of the evidence layer: CycloneDX 1.6 ML-BOM (or 1.7 where tooling supports) with model components carrying full `modelCard` objects (modelParameters, quantitativeAnalysis, considerations, environmentalConsiderations) Cyclonedx and dataset components carrying `governance`, `dataset.type`, `sensitiveData`, `classification`; alternatively SPDX 3.0.1 AI Profile and Dataset Profile Spdx (AIPackage with `safetyRiskAssessment`, `energyConsumption`; FOSSA DatasetPackage with `knownBias`, `anonymizationMethodUsed`, `confidentialityLevel`). Interlynk Build provenance follows SLSA v1.0/ SLSA v1.1 (Build Levels 1-3; Sonar provenance v1 schema with buildDefinition, runDetails); attestations packaged as in-toto ITE-6 Statements (DSSE envelope, SLSA Provenance v1 predicate) signed via Sigstore Fulcio (10-minute X.509 certs bound to OIDC identity) with all signatures published to Rekor. Sigstore Sigstore GitHub Actions `attest-build-provenance` (v4) GitHub achieves SLSA Build Level 2 by default, Level 3 in reusable workflows. PyPI provenance via PEP 740 / 758; npm provenance npm via Trusted Publishing.

The **OSCAL machine-readable representation** (current 1.1.3; FedRAMP minimum supported 1.0.4) GitHub carries all artifacts: Catalog and Profile for the chosen baselines; NIST NIST Component Definition for each substrate primitive; NIST SSP with `import-profile`, `system-characteristics`, `system-implementation`, `control-implementation`; NIST Assessment Plan, Assessment Results, NIST POA&M for the assessment cycle. **FedRAMP RFC-0024 (issued Jan 13, 2026)** Platform28 mandates machine-readable packages for ALL FedRAMP providers — not just 20x — by **September 30, 2026**, Platform28 with loss of certification by September 2027 for non-compliance. This deadline is the single most important date driving v1 timing.

The **logging and detection** layer ingests OpenTelemetry GenAI semantic-convention spans/events (gen_ai.system, gen_ai.request.model, gen_ai.usage.input_tokens, gen_ai.choice) into the SIEM (Splunk HEC, Sentinel DCRs, Chronicle UDM) with five log streams: prompts, completions, tool-use, embeddings, RAG retrieval. Specialized detection layers add prompt-injection detection (Lakera Guard, AppSec Santa Protect AI Rebuff, NVIDIA NeMo Guardrails five-rail architecture, GitHub AWS Bedrock Guardrails, Azure AI Content Safety Prompt Shields), model-extraction detection (rate-limit per identity, query-similarity clustering, output watermarking), and canary tokens for training-data leak detection.

The **incident response** capability adopts NIST SP 800-61 Rev 3 (April 3, 2025) as a CSF 2.0 Community Profile NIST CSRC — replacing the four-phase Rev 2 model Linford Co with GOVERN/IDENTIFY/PROTECT (preparation) and

DETECT/RESPOND/RECOVER (operational handling). Industrial Cyber AI-specific IR patterns are pre-built for prompt-injection, model exfiltration, training-data leak, jailbreak, agent-goes-rogue, supply-chain compromise of model weights, hallucination-induced harm, and content-provenance breach. JCDC.AI Playbook (Jan 2025) channels are wired in (CISA Voluntary Cyber Incident Reporting portal, CISA.JCDC@cisa.dhs.gov). CISA EU AI Act Article 73 reporting (15-day default; 2-day for widespread infringement; EU-ai immediate for critical-infrastructure disruption) is supported for transatlantic exposure.

Phase-4 deliverables: every substrate primitive deployed and configured; full evidence pipeline emitting OSCAL Assessment Results continuously; CI/CD pipeline gating model deployment on Inspect/HELM/lm-eval-harness evaluation thresholds with results signed as in-toto attestations; SIEM dashboards live; IR runbooks tested; tabletop AAR corrective actions closed.

Phase 5 — Evaluation and authorization (6–12 weeks)

Independent assessment is performed by an A2LA-accredited 3PAO (or C3PAO for CMMC L2; DCMA DIBCAC for L3) operating independently from the advisory team — FedRAMP rules prohibit a single firm from providing both advisory and assessment for the same authorization. Coalfire **Authorization package** is assembled as the OSCAL bundle: SSP, SAP, SAR, POA&M, components, profile.

For **FedRAMP 20x Moderate**, the package is built around 56-63 KSIs (Phase-2 added KSI-AFR theme, KSI-CNA-08, KSI-MLA-08, KSI-SVC-08/09/10) Platform28 with ≥70% automated evidence (Phase-2 floor; trending toward 80%). Vanta announced the first 20x Moderate authorization on April 28, 2026; Vanta Telos Corporation Phase-3 wide-scale opens Q3-Q4 2026. Platform28 +2 FedRAMP 20x replaces narrative ConMon with KSI/ADS/PVAS/SCN — KSIs validated every 3 days for machine-validated evidence and every 3 months for non-machine evidence. AWS Telos Corporation

For **DoD RMF / IL5 ATO**, the package follows DoDI 8510.01 with eMASS ingestion: categorization per FIPS 199 + CNSSI 1253, U.S. Department of Defense FedRAMP High + FedRAMP+ uplift per CC SRG Table D-1, Fortreum BCAP/CNAP architecture, SCCA control inheritance matrix, STIG/SRG scan results, FIPS 140-3 module list, identity overlay, ZT RA pillar mapping (152 activities target/advanced), RAI Toolkit, classification-by-aggregation memo, CDAO Generative AI Guidelines self-attestation, AIBOM, ConMon plan with cATO target. The DoD CIO Feb 4, 2022 cATO memo requires three demonstrated competencies: continuous monitoring, active cyber defense, and adoption of an approved DevSecOps reference design. Executive Gov FedTech Magazine

For **CMMC L2 (C3PAO)**, the package follows 32 CFR Part 170 with NIST 800-171 Rev 2 still binding (DoD class deviation — Rev 3 published May 2024 not yet incorporated): 110

practices scored against 320 NIST 800-171A objectives; Isidefense +2 conditional certification at ≥88/110 with 180-day POA&M closeout; ESP inventory; CUI flow diagram; AI-vendor contractual artifacts (no-train, ZDR clauses, BAA, NIST 800-171 attestation, FedRAMP authorization where applicable); annual affirmation by senior official in SPRS. The Protiviti View

For **M-25-21 high-impact AI**, the pre-deployment evaluation report covers all seven minimum risk-management practices with verbatim §4(c) traceability: pre-deployment testing in real-world context with risk-mitigation plans; Carahsoft AI Impact Assessment with seven elements (purpose, data quality, impacts, schedule, cost, independent review results, risk acceptance); ongoing monitoring; human training; additional human oversight; consistent remedies/appeals; public consultation/feedback. carahsoft Wiley CAIO sign-off is mandatory; Federal Reserve waivers require centrally tracked written determination, OMB notification Perkins Coie within 30 days Carahsoft of significant change, public summary, and annual recertification. carahsoft Federal Reserve

Phase-5 deliverables: 3PAO/C3PAO/DIBCAC assessment report; SAR with Risk Exposure Table; ATO/authorization letter; FedRAMP Marketplace listing or eMASS authorization decision document; CAISI-aligned capability evaluation report (where applicable); red-team findings closeout; pre-deployment evaluation report.

Phase 6 — Continuous monitoring and re-authorization (ongoing)

Continuous monitoring under FedRAMP 20x is structured around KSIs, ADS feeds, PVAS submissions, and SCN replacing SCRs (notify, don't ask). OSCAL machine-readable evidence flows continuously into the agency's collaborative continuous monitoring Telos Corporation queue. M-25-21 ongoing monitoring includes performance and adverse-impacts monitoring PwC for safety, privacy, civil rights, civil liberties; Carahsoft carahsoft periodic human review of decisions; annual recertification of waivers. GPAI Code of Practice Measure 7.7 reporting is supported via the EU SEND platform European Commission Europa for any provider of GPAI models with systemic risk (≥10^{25} FLOPs presumed) selling into EU member states. Annual re-assessment against updated baselines is calendared automatically (CMMC affirmations annually; FedRAMP annual assessment continues even under 20x; ISO 42001 surveillance audits Years 1-2, recertification Year 3). Incident disclosure pipeline routes events through both JCDC.AI (US) and EU AI Act Art. 73 (where applicable; 15-day default, 2-day widespread, EU-ai immediate critical-infrastructure).

---

3. Working-level artifacts (the playbook)

Discovery questionnaires are organized as one per pillar plus a cross-cutting organizational instrument. Pillar-1 questions cover policy currency, AIA completion, model-card and datasheet presence, AIBOM coverage; Pillar-2 covers IR playbook readiness, MTTD/MTTR baselines, TTX cadence, JCDC.AI participation; Pillar-3 covers concentration-risk register currency, multi-cloud burst posture, dataset diversity; Pillar-4 covers MFA enforcement depth, SPIFFE deployment, agent identity, microsegmentation maturity; Pillar-5 covers role-responsibility matrix completeness, evidence registry hash-chain integrity, regulator-package portability. Cross-cutting organizational questions cover CAIO designation, AI Governance Board cadence, AI Strategy currency, AI Use Case Inventory accuracy, OneGov vehicle alignment. Modeled on the FedRAMP RAR pre-RAR pattern (~200+ keyed evidence requests) plus the CMMC Pre-Assessment Scoping Guide (CUI Asset / Security Protection Asset / Contractor Risk-Managed / Specialized / Out-of-Scope categorization) U.S. Department of Defense plus an ISO 42001 initial review checklist (Stage 0 readiness, Stage 1 documentation review preparation).

Control checklists are produced as cross-walk matrices mapping each NIST 800-53 Rev 5 control (across 20 families AC/AT/AU/CA/CM/CP/IA/IR/MA/MP/PE/PL/PM/PS/PT/RA/SA/SC/SI/SR — the latter two new in Rev 5) to NIST AI RMF subcategories (GOVERN 1-6, MAP 1-5, MEASURE 1-4, MANAGE 1-4), Nist ISO 42001 Annex A nine objectives (A.2–A.10, 38 controls), Elevate CMMC 14 domains (AC/AT/AU/CM/IA/IR/MA/MP/PS/PE/RA/CA/SC/SI), U.S. Department of Defense FedRAMP 20x KSI themes (CNA/SVC/IAM/MLA/CMT/PIY/CED/AFR/INR/RPL/TPR), and the five framework pillars. The checklist is implemented as an OSCAL Catalog with crosswalk metadata, allowing single-source-of-truth control definitions to project into any of these frameworks on demand.

Evidence templates:

The model card template follows Mitchell et al. 2019's nine sections (Model Details, Intended Use, Factors, Metrics, Evaluation Data, Training Data, Quantitative Analyses, Ethical Considerations, Caveats and Recommendations) Angelevan with Hugging Face YAML metadata schema for machine-readable header (language, license, library_name, tags, pipeline_tag, FriendliAI datasets, metrics, base_model, model-index, co2_eq_emissions). Hugging Face Federal extensions per OMB M-26-04 (Dec 2025 Unbiased AI Principles): bias evaluation results, benchmark scores, governance tools used, red-teaming activities, foreign-training disclosures, modifications made to comply with non-U.S. regulations.

The datasheet template follows Gebru et al. 2018/2021 (Communications of the ACM Dec 2021) with seven sections / 57 questions (Motivation, Composition, Collection Process, Preprocessing/Cleaning/Labeling, Uses, Distribution, Maintenance).

Open Government Portal Mdsd4health The system card template follows Anthropic Claude Opus 4.6 (Feb 2026) and OpenAI GPT-5/o3 patterns: Introduction, Capabilities, Safety Evaluations, User Wellbeing, Honesty, Agentic Safety, Alignment Assessment, Responsible Scaling Policy / Preparedness Framework evaluations, Mitigations & Deployment, Changelog.

The AIBOM template uses CycloneDX 1.6 ML-BOM JSON with `component.type = "machine-learning-model"` triggering the structured `modelCard` object (modelParameters with approach.type / task / architectureFamily / modelArchitecture / datasets / inputs / outputs / hyperparameters; Cyclonedx quantitativeAnalysis with performanceMetrics; considerations with users / useCases / technicalLimitations / ethicalConsiderations / fairnessAssessments; environmentalConsiderations) — alternatively SPDX 3.0.1 AIPackage. The SBOM template uses CycloneDX 1.6 / SPDX 3.0.1 with the CISA 2025 Minimum Elements draft NPRM additions (Software Producer renamed from Author; Component Version with creation-date substitute; License and Copyright Holder; VEX/CSAF integration). CISA SLSA provenance is the in-toto ITE-6 Statement with SLSA Provenance v1 predicate.

PIA templates follow OMB M-03-22's The White House seven required sections (information collected, why, intended use, sharing, opportunities to decline, security, system-of-records determination); DHS, VA, GSA, and CFPB agency-specific extensions add AI-specific fields per their M-25-21 Compliance Plans (Sept 2025). AI Impact Assessment templates follow M-25-21 §4(c)(2)'s seven elements — extended with Canada's Algorithmic Impact Assessment Open Government Portal 65 risk + 41 mitigation questions (106 total) to support transatlantic engagements, mapping to four impact levels (I–IV). Canada.ca IR Plan template follows NIST 800-61 Rev 2 structure (Mission, Strategies & Goals, Senior Mgmt Approval, Org Approach, Communications, Metrics, Roadmap, Integration with Mission) overlaid with Rev 3's CSF 2.0 community-profile guidance. ISCP template follows NIST 800-34 Rev 1's NIST five sections (Supporting Information, Activation & Notification, Recovery, Reconstitution, Plan Appendices) with MTD/RTO/RPO from the BIA. ScienceDirect

Five-pillar maturity model. The rubric is a 5×4×3 matrix (pillars × stages × cross-cutting capabilities) producing 60 cells. Worked example for a single cell — Pillar 4 (Zero Trust) × Identity function × Optimal stage: "Phishing-resistant MFA (FIDO2/WebAuthn or PIV/CAC) enforced enterprise-wide; Medium SPIFFE SVIDs issued for 100% of workloads with 1-hour validity and 30-min rotation; agent identities issued under CAISI-aligned standards (DID or CIMD-equivalent) with delegation-chain attestations; continuous risk-based reauthentication based on real-time device-posture and behavior analytics; mean time-to-revoke < 60 seconds; identity-store federation across all clouds and partner organizations." The 60 cells map directly to: NIST CSF 2.0 tiers, CMMC L1/L2/L3, FedRAMP 20x KSI completion percentages, DoD ZT Target/Advanced activity

counts, ISO 42001 conformance levels.

Sample audit reports. FedRAMP SAR follows the eight-section template (Executive Summary, System Overview, Assessment Methodology, Test Cases / SRTM, Findings with Risk Exposure Table at Critical/High/Moderate/Low, Risks Knowingly Accepted, Recommendations, 3PAO Authorization Recommendation) with nine appendices (RET, Pen Test, Authentication Worksheet, Sampling Methodology, Rules of Engagement, Control Tailoring, Vulnerability Scan, Inventory, Auxiliary). FedRAMP SSP follows the 13-section template per NIST SP 800-18 Rev 1 with FedRAMP-specific appendices (Information Security Policies & Procedures, User Guide, Digital Identity Worksheet, Rules of Behavior, ISCP, CMP, IRP, ConMon Plan, Integrated Inventory Workbook, FIPS 199 Worksheet, Separation of Duties Matrix, Customer Responsibility Matrix). CMMC assessment report follows 32 CFR 170.18 with scoping per §170.19, evidence collection per NIST 800-171A, scoring per §170.24 (110-point scale, 1/3/5 weights), conditional vs final status with eMASS submission. ISO 42001 audit report follows ISO 17021-1 §9.4.8 (CB identification, audit type, criteria, objectives, scope, team, dates, findings, nonconformity classification, conclusions, certification recommendation) with Stage 1 documentation review preceding Stage 2 implementation audit. SOC 2 Type II follows the five-section template (Independent Auditor's Report, Management Assertion, System Description per DC-200, Trust Services Criteria & Tests with Exceptions, optional Other Information) with TSC categories (Security required, Availability/Processing Integrity/Confidentiality/Privacy optional). Secureframe McKonly & Asbury

Authorization-package contributions. The framework produces specific outputs that land in each regulatory package: into a FedRAMP 20x package — KSI evidence stream with traceability to underlying 800-53 controls, OSCAL SSP/SAP/SAR/POA&M, Trust Center URL, AIBOM, model cards, KSI-AFR-MAS Minimum Assessment Scope, KSI-AFR-VDR Vulnerability Detection & Response severity matrix, KSI-AFR-SCN Significant Change Notification AWS policy. Into a DoD RMF ATO package — DoD Rev 5 SSP Addendum, FedRAMP+ control delta evidence, BCAP/CNAP architecture, SCCA inheritance matrix, RAI Toolkit checklist, classification-by-aggregation memo, CDAO Guidelines self-attestation. Into a CMMC certification package — SSP for the 110 NIST 800-171 Rev 2 practices, POA&M (for L2 C3PAO eligible items only), SPRS basic/medium/high score, ESP inventory with control inheritance, CUI flow diagram, annual affirmation by senior official, CMMC UID for each information system. Squire Patton Boggs Into M-25-21 compliance evidence — high-impact determination memo, AIA, pre-deployment testing report, independent-review attestation, ongoing-monitoring plan, training records, oversight design, appeals process documentation, public-feedback log, AI Use Case Inventory entry, waiver memo (if any). Into GSA AI clause compliance evidence — vendor IP/data clauses per M-25-22, no-train provisions,

vendor-lock-in protections, performance-monitoring rights, foreign-training disclosure (M-26-04).

Evidence pipeline architecture. A hash-chained artifact registry stores every artifact under a SHA-256 digest; in-toto ITE-6 attestation envelopes wrap each artifact with one of the vetted predicate types GitHub GitHub (SLSA Provenance v1, SLSA Verification Summary, SBOM Reference, Test Result, Vulnerability, SCAI, Runtime Trace); Sigstore Fulcio issues 10-minute keyless code-signing certs bound to OIDC identity; Andrew Lock Sigstore Rekor publishes signature transparency log entries with Merkle inclusion proofs; GitHub OSCAL machine-readable representation cross-references artifacts via UUIDs; NIST cross-pillar evidence cross-referencing is achieved through shared artifact UUIDs across SSP/SAP/SAR/POA&M; regulator-ready submission packaging produces format-specific bundles (FedRAMP OSCAL, CMMC eMASS, ISO 42001 audit-trail PDF, EU AI Act Article 73 template, GPAI Measure 7.7 SEND platform JSON); litigation-hold preservation freezes the hash-chained registry on demand with immutable WORM storage.

---

4. Roadmap layer (board-readable)

The 12-18 month roadmap is structured with quarterly gates aligned to FITARA scorecard conventions and agency AI Strategy templates per M-25-21 §2(a). carahsoft Key dashboard metrics monitored at every gate:

Metric	Q1 floor	Q4 target
% AI inventory classified, high-impact flag set	70%	100%
% high-impact AI with current AIA (≤12 months)	40%	100%
% systems with current AIBOM (CycloneDX/SPDX 3.0.1 AI Profile)	25%	90%
Mean time to attest (continuous compliance / annual affirmation)	30 days	≤ 7 days
OSCAL coverage % of FedRAMP boundaries	30%	100% (Sept 2026 RFC-0024 deadline)
Red-team finding burndown	baseline	90-day SLA on N1/N2
ConMon currency (KSI evidence within target cadence)	80%	95%

360-Accountability role coverage	70%	100%
% Components reporting CMMC UID(s) for CUI-handling AI	50%	100%
DoD ZT 152-activity coverage	60%	75% (FY27 Target)

Q1 (May–Jul 2026) — Foundation & Inventory. Decision gate: approve AI Strategy refresh and AI Governance Board charter. Milestones: confirm CAIO designation; refresh AI Strategy on agency.gov/ai; publish Compliance Plan; **update IT/data/cyber/privacy policies by May 6, 2026 (M-25-21 deadline)**; issue Generative AI Acceptable Use Terms; carahsoft rebaseline AI Use Case Inventory.

Q2 (Aug–Oct 2026) — High-Impact Determinations & Evidence Uplift. Decision gate: risk-acceptance vote on initial high-impact AI portfolio and any waivers. Milestones: complete high-impact determinations; complete AIAs for top decile by risk; stand up AIBOM tooling; **submit minimum-practices report to OMB by September 22, 2026 (M-25-21 deadline)**; carahsoft Carahsoft **complete OSCAL conversion before September 30, 2026 (FedRAMP RFC-0024 deadline)**; Elevate file annual AI Use Case Inventory.

Q3 (Nov 2026–Jan 2027) — CMMC Phase 2 Cliff & FedRAMP 20x Phase 3 Onramp. Decision gate: approve discontinuation list for non-compliant high-impact AI; approve Phase-2 CMMC contract awards. Milestones: **CMMC Phase 2 active Nov 10, 2026 — L2 C3PAO required for most CUI contracts**; Pivot Point Security +2 complete IL5 reauthorizations; consume 20x Phase 3 marketplace listings; complete annual §4(c) recertifications; begin NIST 800-171 Rev 3 voluntary uplift planning.

Q4 (Feb–Apr 2027) — Optimization, Independent Audit, Pilot-to-Production Surge. Decision gate: approve FY28 budget alignment; approve sunset of pilots that did not graduate. Milestones: GAO-style independent audit of CAIO program; pilot graduation surge target 50%; begin FedRAMP Rev 5 sunset migration (Phase 5 expected Q3-Q4 2027).

Q5–Q6 (May–Oct 2027) — Sustain. Decision gates: quarterly continuous-monitoring approvals; CMMC Phase 3 (Nov 10, 2027) DIBCAC L3 readiness eCFR for highest-priority programs. Secureframe Sustain steady-state KSIs at 3-day machine cadence / 3-month non-machine; annual SPRS affirmations; quarterly red-team cycle with N1/N2 ≤90-day SLA.

Budget ranges by phase (mid-size agency, single-Component scope):

- Phase 1 Discovery: $0.15-0.4M

- Phase 2 Assessment: $0.4-1.2M
- Phase 3 Design: $0.3-0.8M
- Phase 4 Implementation: $1.5-8M (varies most by scenario)
- Phase 5 Authorization: $0.5-2M (3PAO/C3PAO/DIBCAC fees)
- Phase 6 ConMon: $0.3-1.5M/yr

Staffing peaks during Phase 4 at 8-12 FTE (FedRAMP Moderate AI SaaS), 6-10 FTE (DoD GenAI ATO), 4-8 FTE (CMMC L2 DIB AI), 5-9 FTE (civilian rights-impacting AI).

Risk register and mitigation: political/regulatory churn (mitigation: durable-spine NIST/ISO catalogs that survive administrations); FedRAMP 20x scope changes (mitigation: dual Rev 5 + 20x readiness through Phase 3); CMMC rollout slippage (mitigation: voluntary readiness ahead of Phase 2 Nov 2026 cliff); EU AI Act extraterritorial pull (mitigation: ISO 42001 + AIGP credentialing); 800-171 Rev 2→3 transition (mitigation: ODP-ready SSPs in anticipation of DoD class-deviation rescission); GSA "American AI" clause uncertainty (mitigation: durable IP/data terms regardless of clause final text). Stakeholder communication plan layers Agency Head all-hands → Congressional FITARA briefings → OMB CAIO Council → CIO/CDO Council → public agency.gov/ai → Component webinars → industry/3PAO/C3PAO partner calls.

Integration with existing zero-trust roadmaps progresses CISA ZTMM stages (Traditional → Initial → Advanced → Optimal) Stern Security +2 on the civilian side and DoD ZT Strategy activities (152 capabilities target by FY27 Target / FY32 Advanced) on the defense side, with the framework's Pillar 4 maturity model functioning as a unified layer projecting onto both.

---

5. Four worked scenarios

Scenario A — DoD GenAI Assistant under M-25-21 + DoD ZT

DoD and NSS are explicitly **excluded from M-25-21**, Carahsoft +2 but DoD implements a parallel stack: DoDD 5144.02; DoDI 8500.01; DoDI 8510.01 RMF; DoDI 5000.82; DoDI 5200.48 CUI; DISA Cloud Computing SRG (v1r1, June 14, 2024) defining IL2/IL4/IL5/IL6 Fortreum with IL5 = FedRAMP High + FedRAMP+ delta; Fortreum SCCA architecture; DoD ZT Strategy + RA v2.0 (152 activities, FY27 Target); Breaking Defense +2 DoD CIO Generative AI memos (Aug 23, 2023 baseline; Service-specific guidance from DAF, DON, Army CIO 27 Jun 2024); CDAO Generative AI Guidelines; Task Force Lima Executive Summary (Dec 2024) and AI Rapid Capabilities Cell ($100M FY24/25 RDT&E

with $35M four-pilot tranche; DefenseScoop $200M Anthropic ceiling); JWCC IDIQ; CDAO Tradewinds; CNSSI 1253; DoDI 5400.19 PA labeling. Reference exemplars: NIPRGPT (AFRL), CamoGPT (Army), Ask Sage on cArmy IL5 Ask Sage with $10M agreement and OSD/Joint Staff/CCMD expansion (Air & Space Forces Magazine 2025), Acqbot, Microsoft Copilot for DoD, Anthropic Claude Gov on AWS Bedrock IL4/IL5 Anthropic and Secret Region IL6, Claude Claude for Government via Palantir PFCS-SS at FedRAMP High. Claude

Implementation sequence: 30 days = stakeholder mapping with Mission Owner / AO / CDAO RAI Lead / Component CIO / contracting officer; 60 days = CSP DoD PA confirmed at appropriate IL, DISA FIPS 199 + CNSSI 1253 categorization, FedRAMP+ delta selection, RAI Toolkit completion; 90 days = identity overlay deployed (CAC/PIV + FIDO2), SCCA control inheritance documented, BCAP/CNAP architecture approved by DoD CIO; U.S. Department of Defense 6 months = SSP + Rev 5 SSP Addendum complete, STIG/SRG scans clean, red-team complete (prompt injection, jailbreak, classification-by-aggregation), AIBOM v1, DoDI 5400.19 PA-labeling plan; 12 months = ATO issued by AO, ConMon plan in eMASS with cATO target, IL6 expansion path scoped where mission requires.

Authorization package: Component AO ATO letter, eMASS package, CSP DoD PA letter, BCAP approval, SCCA inheritance matrix, RAI Toolkit checklist, classification-by-aggregation memo, CDAO Guidelines self-attestation, AIBOM, model cards for each underlying LLM, red-team report. Staffing: 6-10 FTE (program partner cleared, DoD RMF SME in eMASS, ISSO + ISSE, AI/ML engineer, AI red team lead, cloud security engineer, privacy/records lead, OSCAL/documentation engineer, ConMon engineer). Cost: pilot $8-9M for 12-18 months per AI RCC; enterprise IL5 deployment $5-15M/yr; authorization $1.5-5M one-time; recurring red-team $0.3-1M/yr. Scenario-specific risks: cross-Component reciprocity failure (Army block of NIPRGPT Air & Space Forces Magazine post-Air-Force ATO is the canonical precedent); classification-by-aggregation as flagged in Task Force Lima Executive Summary; U.S. Air Force vendor lock-in mitigated by LLM-agnostic gateway pattern; DDIL operational continuity via Ask Sage Edge or equivalent.

Scenario B — FedRAMP 20x Moderate AI-enabled SaaS

Regulatory stack: FedRAMP Authorization Act (44 U.S.C. § 3607); Coalfire OMB M-24-15; FedRAMP Rev 5 Moderate baseline (323 controls Vanta — legacy path through end of 2027); **FedRAMP 20x program** with Phase-2 closed Moderate pilot (Nov 2025–Mar 31, 2026; ~13 participants Platform28 Workstreet including Vanta, Secureframe, Confluent), Phase-3 wide-scale Q3-Q4 2026, Platform28 Workstreet Phase-4 High pilot Q1-Q2 2027, Phase-5 Rev 5 sunset Q3-Q4 2027. Workstreet KSI structure: 56-63 KSIs across CNA/SVC/IAM/MLA/CMT/PIY/CED/AFR/ Workstreet INR/RPL/TPR/SCR themes

with ≥70% automated evidence (Phase-2 floor). Platform28 RFC-0024 (Jan 13, 2026) mandates OSCAL machine-readable for ALL FedRAMP providers by Sept 30, 2026. Platform28 Platform28 FedRAMP Emerging Technology Prioritization for GenAI (June 2024) supports 12 GenAI cloud services across four capability classes; stackArmor FedScoop first three AI Prioritization 20x Low authorizations targeted Jan 2026. Executive Gov

Implementation: 30 days = Trust Center scaffolding on cloud-native foundation (AWS GovCloud / Azure Government / GCP Assured Workloads), KSI gap analysis, OSCAL repository init; 60 days = phishing-resistant MFA (FIDO2/WebAuthn only — KSI-IAM-01) and FIPS 140-3 modules verified, AI runtime hardened (NeMo Guardrails, prompt firewall, tenant-isolated vector store), continuous validation pipeline emitting JSON evidence every 3 days; 90 days = OSCAL SSP/SAP draft, AIBOM published per CycloneDX 1.6 ML-BOM, model cards published, red-team report; 6 months = 3PAO collaborative assessment, KSI implementation complete with traceability to underlying 800-53 controls, KSI-AFR-MAS / KSI-AFR-VDR / KSI-AFR-SCN documents finalized; 12 months = 20x Moderate authorization issued, FedRAMP Marketplace listing, agency consumption begins via collaborative continuous monitoring.

Authorization package: OSCAL SSP/SAP/SAR/POA&M components/profile NIST in JSON/XML, KSI implementation plan with pass/fail criteria, machine-readable continuous-validation evidence stream, Trust Center URL, IAM evidence, FIPS 140-3 module inventory, AI artifacts (model cards, opt-in training-data attestation, prompt-firewall logs, AIBOM), 3PAO attestation, FedRAMP authorization letter. Staffing 8-12 FTE; cost Rev 5 path historically $1-3M initial + $0.5-1.5M/yr ConMon; 20x compresses initial cost (<$1M target) while front-loading engineering investment in automation. Coalfire Risks: Phase-2 complexity (FedRAMP itself acknowledged most CSPs cannot meet Phase-2 Moderate requirements in expected timelines); FedRAMP Oct 1-Nov 13, 2025 government shutdown impact on Phase-1 reviews; FedRAMP OSCAL deadline cliff Sept 2026; AI Prioritization timeline customization. Recent precedents: Vanta first 20x Moderate (April 28, 2026); Vanta Confluent textbook proposal; FedRAMP Secureframe Phase-2 participation; Secureframe Anthropic Claude for Government FedRAMP-High via PFCS-SS with Schellman. Claude

Scenario C — CMMC L2 (C3PAO) for DIB AI use case

Regulatory stack: DFARS 252.204-7012/-7019/-7020/-7021/-7025; **32 CFR Part 170** (CMMC Program Rule, effective Dec 16, 2024); Greypike **48 CFR final rule effective November 10, 2025** The Protiviti View +2 with phased rollout — Phase 1 Nov 2025-Nov 2026 (L1/L2 self introduced as pre-award conditions); Getpeerless +2 **Phase 2 Nov 2026-Nov 2027 (L2 C3PAO required for most CUI contracts) — the principal cliff**; Pivot Point Security Isidefense Phase 3 Nov 2027-Nov 2028 (L3 DIBCAC); Isidefense full

implementation Nov 2028. Secureframe NIST SP 800-171 Rev 2 remains binding (DoD class deviation pinning Rev 2 despite Rev 3 publication May 2024); Holland & Knight 110 controls Greypike in 14 domains Huntress scored against 320 NIST 800-171A objectives; Isidefense +2 conditional certification at ≥88/110 with 180-day POA&M closeout for eligible items only. SPRS reporting; StrikeGraph CMMC UID per system; annual affirmation by senior official.

AI-specific scenario gotchas: (a) commercial LLM API calls with CUI inputs constitute CUI mishandling and ESP failure if vendor lacks ZDR/no-train clauses; (b) embeddings and model weights derived from CUI training are CUI-derivative subject to 7012 safeguarding; (c) prompt logs containing CUI are themselves CUI requiring disposition controls; (d) third-party model vendors as ESPs requiring inheritance documentation. DoJ Civil Cyber-Fraud Initiative (Oct 2021) creates False Claims Act exposure for inaccurate SPRS scores or affirmations.

Implementation: 30 days = scope determination (FCI vs CUI flows, define CUI enclave often as separate tenant), enumerate ESPs including AI vendors; 60 days = CUI enclave deployed (M365 GCC High or AWS GovCloud / Azure Government), STIG baselines, FIPS 140-3 modules, AI sublayer with ZDR/no-train contracts (Anthropic 2026 NIST 800-171r3 attestation pattern; Claude Bedrock GovCloud; Azure Government OpenAI); 90 days = SSP for 110 practices, ESP inheritance matrix, CUI flow diagram, SPRS basic score; 6 months = mock C3PAO assessment, POA&M built only for L2-eligible items, AT/MP/PE evidence, IR plan with 72-hour reporting; 9-12 months = C3PAO assessment, conditional or final certification, CMMC UID assignment, annual affirmation.

Authorization package: SSP, POA&M, SPRS score, C3PAO assessment report, annual affirmation, CMMC UID(s), ESP inventory, CUI flow diagram, AI vendor contractual artifacts, IR plan, DoD-ODP-aligned configuration evidence (in anticipation of Rev 3). Staffing 4-8 FTE; cost L1 self $25-75K, L2 self $100-300K, L2 C3PAO $200-700K assessment + $0.5-2M total program first year, AI add-on $50-300K. Risks: class-deviation lock at Rev 2 with Rev 3 transition pending; Phase-2 Nov 10, 2026 cliff with C3PAO capacity squeeze; conditional 180-day clock; FCA exposure; commercial LLM with CUI mishandling.

Scenario D — Civilian rights-impacting AI under M-25-21

Regulatory stack: OMB M-25-21 (April 3, 2025; Wiley Hunton supersedes M-24-10) with seven minimum risk-management practices for high-impact AI Wiley per §4(c); M-25-22 procurement memo (solicitations issued ≥Sept 30, 2025); Wiley EO 14179; EO 13960; AI in Government Act 2020; Advancing American AI Act The White House (FY23 NDAA §7224(b)); Privacy Act of 1974; Section 508; Title VI/ADA/FHA/ECOA where applicable; FISMA; OMB Circular A-130; M-26-04 (Dec 2025 Unbiased AI Principles

disclosure).

Verbatim seven minimum practices per §4(c): (1) Pre-deployment testing in real-world context with risk-mitigation plans; Carahsoft (2) AI Impact Assessment (purpose, data quality, impacts, schedule, cost, independent review, risk acceptance); (3) Ongoing monitoring for performance and adverse impacts on safety/privacy/civil rights/civil liberties; Carahsoft PwC (4) Adequate human training; (5) Additional human oversight, intervention, PwC accountability with fail-safes; Carahsoft (6) Consistent remedies/appeals PwC with timely human review; Carahsoft (7) Consult and incorporate end-user/public feedback. CAIO designation by June 30, 2025 carahsoft (already past); AI Governance Board by Aug 12, 2025; carahsoft AI Strategy/Compliance Plan by Dec 26, 2025; **policy updates by May 6, 2026**; carahsoft **GenAI Acceptable Use by May 6, 2026**; carahsoft **OMB minimum-practices report by Sept 22, 2026**; carahsoft Carahsoft **operational high-impact AI compliance deadline April 3, 2026** (now past for in-operation systems — they must be compliant, waived, or retired).

Reference exemplars: GSA Login.gov face-matching technology (Tier 3 high-impact); GSA SSA benefits eligibility decision support; IRS fraud/identity-verification scoring; USCIS adjudication assist; VA disability rating clinical-evidence assistance; HHS Medicare anomaly detection; CFPB consumer-protection AI; DHS adjudication/risk-scoring tools.

Implementation: 30 days = use-case intake, high-impact determination per §5/§6, scope determination; 60 days = AIA drafted with all seven §4(c)(2) elements, pre-deployment testing plan, independent-evaluator engagement; 90 days = pre-deployment testing executed, independent review attestation, FISMA boundary ATO confirmed; 6 months = ongoing-monitoring metrics live, drift detection, training curriculum and completion records, human oversight design with fail-safes, appeals/remedy process accessible per Section 508; 12 months = public-feedback cycle complete, AI Use Case Inventory entry with high-impact flag and contact email, annual recertification.

Authorization package: high-impact determination memo, AIA, pre-deployment testing report, independent-review attestation, ongoing-monitoring plan, training records, oversight design, appeals process documentation, public-feedback log, AI Use Case Inventory entry, PIA/SORN, FISMA ATO, M-25-22 procurement artifacts, AIBOM and model card, civil-rights impact analysis, waiver memo with public summary (if any), annual recertification. Staffing 5-9 FTE; cost AIA + independent evaluation $50-250K per use case; ongoing monitoring $100-500K/yr; public consultation $25-150K. Risks: §4 deadline cliff (April 3, 2026 has passed for in-operation systems); Sept 22, 2026 OMB reporting deadline; waiver scrutiny (publicly tracked); Hunton Federal Reserve

civil-rights statute exposure; M-25-22 procurement compounding effects.

---

6. Cross-scenario portability

The same architectural primitive produces different concrete artifacts across the four scenarios — this is the portability proof.

SPIFFE/SPIRE workload identity (Pillar 4). In Scenario A (DoD GenAI), SVIDs are issued for inference pods inside the IL5 enclave, with SPIRE Server federated across BCAP boundary and feeding PIV/CAC for human users. In Scenario B (FedRAMP 20x), SPIFFE identities are the substrate of KSI-IAM-04 service-to-service authentication, with mTLS between microservices providing automated evidence for the KSI feed. In Scenario C (CMMC), SPIFFE identities authenticate workloads inside the CUI enclave, with each SVID issuance event logged for audit (AU-2/AU-3). In Scenario D (civilian high-impact AI), SPIFFE identities tag every inference call with the originating workload SVID, providing the audit trail that supports M-25-21 §4(c)(5)'s Wiley human oversight and accountability requirement.

CycloneDX ML-BOM (Pillar 1). Scenario A: ML-BOM accompanies every model deployed inside the IL5 enclave with classification-by-aggregation analysis attached via the considerations.ethicalConsiderations object. Scenario B: ML-BOM is part of the FedRAMP Marketplace listing artifact bundle and is referenced by the AI Prioritization Framework's model card requirement. Scenario C: ML-BOM documents whether any CUI flowed into model training (the considerations.users field flags "CUI access required") and supports the ESP control inheritance matrix. Scenario D: ML-BOM with full quantitativeAnalysis and considerations.fairnessAssessments populates the M-25-21 §4(c)(2) AIA's carahsoft "data quality" and "potential impacts" elements and is published on the agency.gov/ai page.

OSCAL machine-readable evidence (Pillar 5). Scenario A: OSCAL SSP feeds eMASS for Component AO authorization. Scenario B: OSCAL is mandatory by Sept 30, 2026 (RFC-0024) Platform28 +2 and is the native FedRAMP 20x submission format. Scenario C: OSCAL exports populate SPRS and the C3PAO eMASS submission. Scenario D: OSCAL Assessment Results provide audit-defensible evidence of §4(c) practice implementation and are referenced in the OMB Sept 22, 2026 minimum-practices report.

HSEEP-aligned tabletop exercise (Pillar 2). Scenario A: TTX scenario centers on a prompt-injection event leading to CUI exfiltration in an IL5 GenAI assistant; players include Mission Owner / AO / CDAO RAI / JFHQ-DODIN / Component CIO. Scenario B: TTX scenario centers on an indirect prompt injection via RAG worm in a multi-tenant

SaaS leading to cross-tenant data leak; players include CISO / CSP incident commander / 3PAO liaison / agency consumer. Scenario C: TTX scenario centers on commercial LLM API call inadvertently transmitting CUI to a vendor without ZDR; players include CISO / DoD Component contracting officer / DCSA / DoJ liaison. Scenario D: TTX scenario centers on hallucination-induced harm in a benefits-eligibility decision leading to civil-rights complaint; players include CAIO / Privacy Officer / civil-rights office / GC.

Concentration risk register (Pillar 3). Scenario A: register tracks model-family concentration on Anthropic-via-Bedrock-IL5 with backup paths to Microsoft Copilot for DoD and self-hosted open-weights on JWCC compute. Scenario B: register tracks foundation-model dependency on a single API provider with multi-cloud burst patterns. Scenario C: register tracks commercial LLM ESP concentration with documented contractual exit and CUI-erase obligations. Scenario D: register tracks vendor concentration for the high-impact use case with M-25-22 vendor-lock-in protection in the contract.

---

7. Staffing and competence model

The competence model resolves to nine roles across the engagement lifecycle, with credentials, FY26 loaded hourly rate ranges, and GSA labor-category mappings.

The **Lead Engagement Manager / Engagement Partner** holds PMP/PgMP plus federal program-management experience, 18-25+ years, $300-525/hr, GSA SIN 541611 Senior Manager / Program Director category, medium scarcity (cleared partners are the constraint).

The **AI Governance Lead** holds IAPP AIGP (launched March 5, 2024; HPCwire BoK v2.1 April 2026), ISO 42001 Lead Auditor (Exemplar Global / IRCA / PECB / BSI), NIST AI RMF practitioner training, and CIPP/G or CIPP/US complementary credentials, 10-18 years, $235-400/hr, SIN 541611 SME / 54151S AI Governance Architect, **high scarcity** — credential supply lags demand and cleared/federally-experienced AIGPs are particularly scarce.

The **Security Architect** holds CISSP, CISSP-ISSEP, CISM, CCSP plus FedRAMP/RMF authorization expertise, 12-20 years, $215-385/hr, SIN 54151S Senior Security Architect / 54151HACS Key Personnel, medium-high scarcity. The **Privacy Lead** holds CIPP/US, CIPP/G, CIPM, CDPSE, plus CIPP/E if EU AI Act in scope, 10-18 years, $210-370/hr, SIN 541611 / 54151S, medium scarcity (CIPP/G + AIGP combination is rare).

The **AI Red Team Lead** holds OSCP/OSCE/OSEP plus GIAC GCFA/GREM plus an ML degree or equivalent plus Anthropic/OpenAI external red-team alumni status plus

emerging certs (AIRT-1, MITRE ATLAS-aligned), 8-15 years, $250-425/hr, SIN 54151HACS Pen Test Lead + 54151S ML Engineer, **very high scarcity** — fewer than ~500 globally with both offensive security and ML depth.

The **Legal/Compliance Lead** is JD with federal contracts background plus FAR/DFARS expertise plus EU AI Act fluency plus IAPP AIGP and CIPP/E, 10+ years, $250-500/hr (ODC or independent counsel rates on T&M), SIN 541611 Senior Management Consultant, high scarcity (very few have GovCon + AI + privacy intersection).

The **Platform Engineer** holds CKS plus AWS/Azure/GCP "Solutions Architect Pro" + Security Specialty plus Sigstore/SLSA/in-toto familiarity plus OPA/Rego plus SPIFFE/SPIRE plus OSCAL plus OAuth/OIDC plus MCP plus GitOps, 5-12 years, $170-310/hr, SIN 54151S / 518210C, medium-high scarcity. The **3PAO Lead Assessor / C3PAO** is A2LA-accredited (FedRAMP 3PAO requirement, ISO/IEC 17020 + ISO 9001) plus Cyber AB CCA/CCP for CMMC plus pedigree at A-LIGN / Coalfire / Schellman / Fortreum, 10-18 years, $210-360/hr, SIN 54151HACS Lead Assessor — independent of advisory by FedRAMP rule. The **AI Engineer / ML Lead** is PhD or equivalent in ML plus LLM fine-tuning plus evaluation frameworks (HELM, lm-eval-harness, Inspect, DeepEval) plus MLOps plus track record at Anthropic/OpenAI/Hugging Face, 5-12 years, $230-420/hr, SIN 54151S, **high scarcity** for federal-cleared talent.

Worked staffing per scenario: FedRAMP Moderate AI SaaS 8-12 FTE blended ($1-2.5M total); DoD ATO for GenAI tool 6-10 FTE ($5-15M/yr enterprise scale); CMMC L2 readiness 4-8 FTE ($75-300K typical SMB); civilian rights-impacting AI 5-9 FTE ($400K-1.2M FFP).

---

8. Pricing and commercial structure

GSA MAS positioning combines SIN 54151S (T&M IT professional services) for engineering/cyber labor; SIN 541611 (Mgmt Consulting; size standard $27M NAICS 541611) for governance/policy advisory; SIN 541990 (Other Professional Services; size standard $19.5M, the OASIS+ administrative size) for assurance/audit; SIN 611430 for AI literacy training; SIN 518210C for productized OSCAL pipelines and evidence platforms; **SIN 54151HACS (HACS)** for the cyber assurance work — five subcategories (HVA Assessments, RVA, Penetration Testing, Incident Response, Cyber Hunt) plus SAR and SSE. AI red team work as of May 2026 is not a separate HACS subcategory; it is scoped through HACS Penetration Testing or Cyber Hunt, supplemented by SIN 54151S ML labor. Other vehicles include GSA OASIS+ Phase II (continuous open enrollment from Jan 12, 2026) for non-IT advisory; Polaris GWAC for small-business IT (SDVOSB Nov 2025; HUBZone Nov 2025; WOSB initial March 9, 2026); Alliant 3 for unrestricted enterprise IT; 8(a) STARS III; VETS 2 for SDVOSB IT; GSA Centers of Excellence for

government-to-government AI engagements.

Pricing models: **T&M** with FY26 loaded labor rates per the worked competence-model table; **FFP** for FedRAMP Readiness Assessment ($150-400K), FedRAMP Initial Authorization ($500K-2M plus $2M average total CSP investment), 20x Low pilot ($200-600K compressed), CMMC L2 readiness ($50-250K plus $105-118K C3PAO fee), ISO 42001 implementation ($100-500K), AI red team engagement ($75-500K), NIST AI RMF / M-25-21 governance advisory ($250K-1M); **outcome-based** less common but emerging on milestone-payment task orders and FRaaS subscription bundles (Anitian, stackArmor, Coalfire FastRAMP); **CPFF** for SETA/larger programs (DARPA AI Reinforcements HR001124C0309 example at $17.3M).

Set-asides: 8(a), SDVOSB, WOSB/EDWOSB, HUBZone with NAICS-driven size standards (541512 $34M; 541611 $27M; 541990 $19.5M; 541715 1,000 employees). SBA Mentor-Protégé and joint-venture scoring on Polaris/OASIS+. Subcontracting plans on prime contracts >$750K. CTAs preserve each Schedule holder's prices.

IP allocation: civilian FAR 27.4 / 52.227-14 with unlimited rights on first-produced data, limited rights on private-expense data; DoD DFARS 252.227-7013/-7014/-7015 with Government Purpose Rights (5-year default) on mixed-funded development becoming unlimited after the GPR period; SBIR/STTR 20-year exclusion under DFARS 252.227-7018. Engagement IP (methodologies, OSCAL templates, evaluation playbooks) retained as commercial computer software / commercial technical data. Client IP (their data, model weights, configurations) Government-owned. M-25-22 mandates contractual coverage of IP rights, government data ownership, vendor-lock-in protection, and access on contract close-out.

Platform-vs-services revenue: hybrid bundles combine one-time professional-services fee ($150-750K) plus annual platform subscription ($50-500K) plus optional managed continuous monitoring ($200K-1M+/yr). Authorized governance platforms include Telos Xacta (FedRAMP High April 9, 2026), RegScale (OSCAL Hub donation 2025), Anitian, stackArmor Armory20x, Drata, Hyperproof, Paramify (FedRAMP 20x Mod), Vanta (20x Moderate April 28, 2026).

---

9. Risks, assumptions, dependencies

Political/regulatory risk. OMB memo turnover demonstrated within 16 months (M-24-10/M-24-18 → M-25-21/M-25-22). Future administrations could re-shuffle. Durable spine: NIST 800-53, NIST AI RMF, NIST 800-171, ISO 42001, ISO 27001/27701 — statutorily referenced (FISMA, FedRAMP Authorization Act 2023) or globally adopted. **Technical risk.** OSCAL adoption is currently low (FedRAMP itself acknowledged in

2025 that 100+ Rev 5 authorizations were processed without a single OSCAL submission); Sept 2026 RFC-0024 deadline forces rapid migration with vendor-tooling capacity constraint. CAISI Agent Standards are RFI/concept-paper-stage with AI Agent Interoperability Profile targeted Q4 2026 — agent identity primitives in v1 are necessarily proposals, not normative standards. **Litigation risk.** DoJ Civil Cyber-Fraud Initiative (Oct 2021) creates False Claims Act exposure for inaccurate SPRS scores and CMMC affirmations; M-25-21 waiver scrutiny is publicly tracked; civil-rights statute exposure on rights-impacting AI. Mitigations: hash-chained evidence registry; litigation-hold preservation; legal counsel review of every affirmation.

Market risk. EU AI Act extraterritorial pull (GPAI obligations apply Aug 2, 2026; full applicability Aug 2, 2027) requires concurrent ISO 42001 + AIGP + CIPP/E hedging. FedRAMP 20x scope changes — Phase 3 wide-scale Q3-Q4 2026, CR26 publishing by end of June 2026 with new four-class structure. CMMC rollout slippage — Phase 2 cliff Nov 10, 2026, with PreVeil survey indicating 70% of contractors budgeted below DoD's $100K+ Level 2 estimate. NIST 800-171 Rev 2→3 transition pending DoD class-deviation rescission. GSA "American AI" clause (March 2026 proposal; comment period through May 31, 2026) — civil-liberties concerns about "any lawful government purpose" language; mitigation via durable IP/data terms regardless of final clause text.

Durable-spine commitments. v1 commits to: (a) NIST/ISO catalog-anchored controls that survive administrations; (b) machine-readable evidence (OSCAL, in-toto, Sigstore) that survives tooling changes; (c) substrate primitives (SPIFFE, MCP, CycloneDX) that survive vendor-specific platforms; (d) regulator-portable evidence (one assessment, multiple regulator outputs); (e) explicit forward-looking flags on draft standards to prevent over-commitment.

---

10. Critical view

Where the framework genuinely adds value vs restates existing methodologies. The framework's distinctive contribution is **substrate-property reframing**: it treats governance not as documentation but as architectural enforcement, and binds every claim to a machine-readable artifact in the evidence pipeline. The five-pillar maturity model adapted from CISA ZTMM provides a single rubric that simultaneously projects onto NIST CSF 2.0 tiers, CMMC levels, FedRAMP 20x KSI completion, DoD ZT activities, and ISO 42001 conformance — eliminating duplicate assessment effort. The 360-accountability matrix provides a role-control responsibility crosswalk that no single existing framework provides at this granularity. The four-scenario portability proof demonstrates that the same architectural primitive produces different concrete artifacts for different regulators — a property no existing methodology demonstrates explicitly.

Where the framework restates rather than innovates. Phase 1-3 methodology mirrors standard 3PAO RAR pre-RAR pattern (Coalfire/Schellman/A-LIGN/Tevora). NIST 800-53 control evaluation is unchanged. Authorization-package contents are dictated by the regulators. The TTX design follows HSEEP doctrine. These are deliberate fidelity decisions: a framework that diverged would not be auditable.

Which pillars are most operationally mature. Pillar 4 (Zero Trust) is the most mature: PIV/CAC + FIDO2, SPIFFE/SPIRE, Cilium/Istio, GPU-MIG, microsegmentation are production technologies with extensive federal precedent. Pillar 1 (Governance, security, privacy baked in) is moderately mature: CycloneDX 1.6, SPDX 3.0.1, OSCAL, Sigstore, in-toto are stable; AIBOM standardization and OSCAL adoption remain in flight with the Sept 2026 cliff. Pillar 2 (Assumed breach) is moderately mature: NIST 800-61 Rev 3 / JCDC.AI Playbook / HSEEP / MITRE ATT&CK + ATLAS provide ample doctrine; AI-specific CTEPs from CISA are not yet released; AI-specific incident classes and disclosure obligations are still maturing. Pillar 3 (No single point of failure) is the **least mature** because concentration-risk methodology specific to AI is largely absent from federal guidance — the framework's contribution here is the most original. Pillar 5 (360 accountability) is moderately mature: the regulatory primitives exist (M-25-21 §3, ISO 42001 Annex A.3, GAO-21-519SP) but cross-regulator evidence portability is novel.

Open questions v1 explicitly acknowledges. (a) Agent identity primitives — CAISI standards are RFI/concept-paper-stage; CIMD and DID candidates are not yet normative. (b) NIST 800-171 Rev 2→3 transition timing — pinned to DoD class-deviation rescission. (c) FedRAMP 20x Phase 3 wide-scale and 20x High Phase 4 timelines — forward-looking. (d) GSA "American AI" clause final text — comment period extending into May 2026. (e) EU AI Act Article 73 reporting template final form — Commission consultation closed Nov 7, 2025, finalization targeted Aug 2, 2026. (f) AI red team certification ecosystem — AIRT-1 emerging; HACS subcategory absent. (g) GPAI Code of Practice signatory enforcement — Aug 2, 2026 application date. (h) Concentration-risk metrics — no federal-grade quantitative methodology exists; the framework proposes one.

Calibrated confidence statement by audience. For a federal CIO/CAIO sitting across the table from the engagement team: **high confidence** that the framework produces a defensible, audit-ready posture for any of the four scenarios with the timelines, costs, and staffing profiles described, **provided that** the durable-spine commitments are honored and forward-looking elements are revisited at each quarterly gate. For a delivery team executing the methodology: **high confidence** in Phases 1-3 (standard 3PAO/C3PAO methodology); **medium-high confidence** in Phase 4 implementation (substrate primitives are mature but agent identity is in flux); **medium-high confidence** in Phase 5 authorization (FedRAMP 20x Phase-3 wide-scale availability is the largest schedule risk); **high confidence** in Phase 6 continuous monitoring

(KSI/ADS/PVAS/SCN model is well-defined). For major-framework institutions (NIST, FedRAMP PMO, OMB, CISA, DoD CIO, ISO TC SC42) evaluating operational credibility: **high confidence** that the framework's substrate-property reframing is consistent with their published direction and adds non-duplicative value through the role-control crosswalk, the five-pillar maturity model, and the cross-scenario portability proof. Where the framework forward-projects (CAISI agent standards, NIST 800-171 Rev 3 incorporation, FedRAMP 20x High pilot), it does so with explicit forward-looking flags and revision cadence.

The framework's claim to procurement-ready status rests not on completeness — no v1 of any AI governance framework is complete in May 2026 — but on **architectural defensibility**: every claim binds to a machine-readable artifact in the evidence pipeline; every artifact binds to a primary federal source; every primary source binds to a named regulatory baseline. That is the substrate, and it is what governance becomes when it stops being a document.